

TryHackMe: Nmap (furthernmap)

<https://tryhackme.com/p/abinrd>

abinrd@mulearn

random), which it uses for all its communications with the remote server.

Every computer has a total of 65535 available ports; however, many of these are registered as standard ports. For example, a HTTP Webservice can nearly always be found on port 80 of the server. A HTTPS Webservice can be found on port 443. Windows NETBIOS can be found on port 139 and SMB can be found on port 445. It is important to note; however, that especially in a CTF setting, it is not unheard of for even these standard ports to be altered, making it even more imperative that we perform appropriate enumeration on the target.

If we do not know which of these ports a server has open, then we do not have a hope of successfully attacking the target; thus, it is crucial that we begin any attack with a port scan. This can be accomplished in a variety of ways – usually using a tool called nmap, which is the focus of this room. Nmap can be used to perform many different kinds of port scan – the most common of these will be introduced in upcoming tasks; however, the basic theory is this: nmap will connect to each port of the target in turn. Depending on how the port responds, it can be determined as being open, closed, or filtered (usually by a firewall). Once we know which ports are open, we can then look at enumerating which services are running on each port – either manually, or more commonly using nmap.

So, why nmap? The short answer is that it's currently the industry standard for a reason: no other port scanning tool comes close to matching its functionality (although some newcomers are now matching it for speed). It is an extremely powerful tool – made even more powerful by its scripting engine which can be used to scan for vulnerabilities, and in some cases even perform the exploit directly! Once again, this will be covered more in upcoming tasks.

For now, it is important that you understand: what port scanning is; why it is necessary; and that nmap is the tool of choice for any kind of initial enumeration.

Answer the questions below

What networking constructs are used to direct traffic to the right application on a server?

Ports

✓ Correct Answer

How many of these are available on any network-enabled computer?

65535

✓ Correct Answer

[Research] How many of these are considered "well-known"? (These are the "standard" numbers mentioned in the task)

1024

✓ Correct Answer

🔍 Hint

Like most pen-testing tools, `nmap` is run from the terminal. There are versions available for both Windows and Linux. For this room we will assume that you are using Linux; however, the switches should be identical. `Nmap` is installed by default in both Kali Linux and the TryHackMe Attack Box.

`Nmap` can be accessed by typing `nmap` into the terminal command line, followed by some of the "switches" (command arguments which tell a program to do different things) we will be covering below.

All you'll need for this is the help menu for `nmap` (accessed with `nmap -h`) and/or the `nmap` man page (access with `man nmap`). For each answer, include all parts of the switch unless otherwise specified. This includes the hyphen at the start (`-`).

Answer the questions below

What is the first switch listed in the help menu for a "Syn Scan" (more on this later)?

`-sS` ✓ Correct Answer

Which switch would you use for a "UDP scan"?

`-sU` ✓ Correct Answer

If you wanted to detect which operating system the target is running on, which switch would you use?

`-O` ✓ Correct Answer

`Nmap` provides a switch to detect the version of the services running on the target. What is this switch?

`-sV` ✓ Correct Answer

The default output provided by `nmap` often does not provide enough information for a pentester. How would you increase the verbosity?

`-v` ✓ Correct Answer

Verbosity level one is good, but verbosity level two is better! How would you set the verbosity level to two?
(Note: it's highly advisable to always use at least this option)

`-vv` ✓ Correct Answer

We should always save the output of our scans – this means that we only need to run the scan once (reducing network traffic and thus chance of detection), and gives us a reference to use when writing reports for clients.

What switch would you use to save the `nmap` results in three major formats?

`-oA` ✓ Correct Answer

What switch would you use to save the `nmap` results in a "normal" format?

`-oN` ✓ Correct Answer

A very useful output format: how would you save results in a "grepable" format?

`-oG` ✓ Correct Answer

Sometimes the results we're getting just aren't enough. If we don't care about how loud we are, we can enable "aggressive" mode. This is a shorthand switch that activates service detection, operating system detection, a traceroute and common script scanning.

How would you activate this setting?

`-A` ✓ Correct Answer

`Nmap` offers five levels of "timing" template. These are essentially used to increase the speed your scan runs at. Be careful though: higher speeds are noisier, and can incur errors!

How would you set the timing template to level 5?

`-T5` ✓ Correct Answer

We can also choose which port(s) to scan.

How would you tell `nmap` to only scan port 80?

`-p 80` ✓ Correct Answer

How would you tell `nmap` to scan ports 1000-1500?

`-p 1000-1500` ✓ Correct Answer

A very useful option that should not be ignored:

How would you tell `nmap` to scan all ports?

`-p-` ✓ Correct Answer

How would you activate a script from the `nmap` scripting library (lots more on this later)?

`--script` ✓ Correct Answer

How would you activate all of the scripts in the "vuln" category?

`--script=vuln` ✓ Correct Answer [Hint](#)

Answer the questions below

Which RFC defines the appropriate behaviour for the TCP protocol?

RFC 9293

✓ Correct Answer

🔍 Hint

If a port is closed, which flag should the server send back to indicate this?

RST

✓ Correct Answer

Answer the questions below

There are two other names for a SYN scan, what are they?

Half-Open, Stealth

✓ Correct Answer

Can Nmap use a SYN scan without Sudo permissions (Y/N)?

N

✓ Correct Answer

Task 7 🟢 Scan Types UDP Scans

Unlike TCP, UDP connections are *stateless*. This means that, rather than initiating a connection with a back-and-forth "handshake", UDP connections rely on sending packets to a target port and essentially hoping that they make it. This makes UDP superb for connections which rely on speed over quality (e.g. video sharing), but the lack of acknowledgement makes UDP significantly more difficult (and much slower) to scan. The switch for an Nmap UDP scan is `(-su)`

When a packet is sent to an open UDP port, there should be no response. When this happens, Nmap refers to the port as being `open|filtered`. In other words, it suspects that the port is open, but it could be firewalled. If it gets a UDP response (which is very unusual), then the port is marked as `open`. More commonly there is no response, in which case the request is sent a second time as a double-check. If there is still no response then the port is marked `open|filtered` and Nmap moves on.

When a packet is sent to a closed UDP port, the target should respond with an ICMP (ping) packet containing a message that the port is unreachable. This clearly identifies closed ports, which Nmap marks as such and moves on.

Due to this difficulty in identifying whether a UDP port is actually open, UDP scans tend to be incredibly slow in comparison to the various TCP scans (in the region of 20 minutes to scan the first 1000 ports, with a good connection). For this reason it's usually good practice to run an Nmap scan with `--top-ports <number>` enabled. For example, scanning with `nmap -su --top-ports 20 <target>`. Will scan the top 20 most commonly used UDP ports, resulting in a much more acceptable scan time.

When scanning UDP ports, Nmap usually sends completely empty requests – just raw UDP packets. That said, for ports which are usually occupied by well-known services, it will instead send a protocol-specific payload which is more likely to elicit a response from which a more accurate result can be drawn.

Answer the questions below

If a UDP port doesn't respond to an Nmap scan, what will it be marked as?

open|filtered

✓ Correct Answer

When a UDP port is closed, by convention the target should send back a "port unreachable" message. Which protocol would it use to do so?

ICMP

✓ Correct Answer

Answer the questions below

Which of the three shown scan types uses the URG flag?

xmas

✓ Correct Answer

Why are NULL, FIN and Xmas scans generally used?

Firewall Evasion

✓ Correct Answer

Which common OS may respond to a NULL, FIN or Xmas scan with a RST for every port?

Microsoft Windows

✓ Correct Answer

Task 9 Scan Types ICMP Network Scanning

On first connection to a target network in a black box assignment, our first objective is to obtain a "map" of the network structure -- or, in other words, we want to see which IP addresses contain active hosts, and which do not.

One way to do this is by using `Nmap` to perform a so called "ping sweep". This is exactly as the name suggests: `Nmap` sends an ICMP packet to each possible IP address for the specified network. When it receives a response, it marks the IP address that responded as being alive. For reasons we'll see in a later task, this is not always accurate; however, it can provide something of a baseline and thus is worth covering.

To perform a ping sweep, we use the `-sn` switch in conjunction with IP ranges which can be specified with either a hyphen (-) or CIDR notation. i.e. we could scan the `192.168.0.x` network using:

- `nmap -sn 192.168.0.1-254`

or

- `nmap -sn 192.168.0.0/24`

The `-sn` switch tells Nmap not to scan any ports -- forcing it to rely primarily on ICMP echo packets (or ARP requests on a local network, if run with `sudo` or directly as the root user) to identify targets. In addition to the ICMP echo requests, the `-sn` switch will also cause `nmap` to send a `TCP SYN` packet to port 443 of the target, as well as a `TCP ACK` (or `TCP SYN` if not run as root) packet to port 80 of the target.

Answer the questions below

How would you perform a ping sweep on the 172.16.x.x network (Netmask: 255.255.0.0) using Nmap? (CIDR notation)

`nmap -sn 172.16.0.0/16`

✓ Correct Answer

🔍 Hint

Task 10 NSE Scripts Overview

The `Nmap Scripting Engine` (NSE) is an incredibly powerful addition to `Nmap`, extending its functionality quite considerably. NSE Scripts are written in the `Lua` programming language, and can be used to do a variety of things: from scanning for vulnerabilities, to automating exploits for them. The NSE is particularly useful for reconnaissance, however, it is well worth bearing in mind how extensive the script library is.

There are many categories available. Some useful categories include:

- `safe` :- Won't affect the target
- `intrusive` :- Not safe: likely to affect the target
- `vuln` :- Scan for vulnerabilities
- `exploit` :- Attempt to exploit a vulnerability
- `auth` :- Attempt to bypass authentication for running services (e.g. Log into an FTP server anonymously)
- `brute` :- Attempt to bruteforce credentials for running services
- `discovery` :- Attempt to query running services for further information about the network (e.g. query an SNMP server).

A more exhaustive list can be found [here](#).

In the next task we'll look at how to interact with the NSE and make use of the scripts in these categories.

Answer the questions below

What language are NSE scripts written in?

`Lua`

✓ Correct Answer

Which category of scripts would be a very bad idea to run in a production environment?

`intrusive`

✓ Correct Answer

Task 13 Firewall Evasion

Task 14 Practical

Use what you've learnt to scan the target machine and answer the following questions!

The IP address of the VM you powered on in Task1 is MACHINE_IP

(Note: If you're not a subscriber, make sure that this machine has had around ten minutes to start)

Answer the questions below

Does the target ip respond to ICMP echo (ping) requests (Y/N)?

N

✓ Correct Answer

Perform an Xmas scan on the first 999 ports of the target -- how many ports are shown to be open or filtered?

999

✓ Correct Answer

There is a reason given for this -- what is it?

Note: The answer will be in your scan results. Think carefully about which switches to use -- and read the hint before asking for help!

No Response

✓ Correct Answer

 Hint

Perform a TCP SYN scan on the first 5000 ports of the target -- how many ports are shown to be open?

5

✓ Correct Answer

Open Wireshark (see [Cryillic's Wireshark Room](#) for instructions) and perform a TCP Connect scan against port 80 on the target, monitoring the results. Make sure you understand what's going on. Deploy the `ftp-anon` script against the box. Can Nmap login successfully to the FTP server on port 21? (Y/N)

Y

✓ Correct Answer

Task 15 Conclusion